SIMATS ENGINEERING

SIMATS
Saveetha Institute of Medical And Technical Sciences

ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.

Code of Conduct:

I S.Venkatesh (192311407) *(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

S. Venkatesh
192311407

1, Unauthorized Vulnerability Discovery

If I discover a Critical Vulnerability outside the approved scope, I will:

1, Avoid exploiting the Vulnerability without permission.

2, Document the Vulnerability safely without causing damage.

3, Inform the Client immediately about the discovery.

4, Obtain written authorization before perpnorming further tests.

5, Follow ethical principles such as authorization, responsible disclosure and avoiding harm.

Conclusion:

A Vulnerability outside the approved scope must not be exploited without proper permission.

2, SQL Injection in a Production Database:

1, Avoid accessing, modifying, or extracting real financial information.

2, Use a safe proof of concept to verify the vulnerability.

3, Prefer a staging environment with dummy data for further testing.

4, Stop testing if sensitive information may be exposed.

5, Inform the client about the vulnerability and its risks.

Pre-cautions before testing:

1, Obtain written authorization and define the testing scope.

2, Arrange backups and test accounts.

3, Establish data-protection rules and confidentiality agreements.

4, Prepare an incident-response and recovery plan.

Conclusion:

Testing must be conducted safely without exposing customer information or disrupting business operations.

of service outage:

Preventive measures:

1, Avoid aggresive testing against live production servers.
2, Establish request limits and safe testing methods.
3, Define emergency stop conditions before starting.
4, Obtain approval for potentially disruptive tests.

Responsibilities after outage:

1, Stop testing immediately.
2, Notify the client and responsible technical team.
3, Assist with system recovery and restoration of services.
4, Preserve Relevant logs and document the incident honestly.
5, Identify the cause and recommend preventive measures.

Conclusion:

Ethical hackers must minimize harm, report incidents immediately and take responsibility for their actions.

4, Testing without informing the IT Dept

Ethical and practical risks:

1, The IT team may mistake the test for a real cyberattack.

2, Emergency responses may be delayed or unnecessarily triggered.

3, Testing uncleanly may cause unexpected system disruptions.

4, Unclear authorization may create legal and professional risks.

Measures to protect the engagement:

1, Obtain written authorization from an appropriate senior authority.

2, Define the scope, objectives and rules of engagement.

3, Establish emergency contacts and stop procedures.

4. Document the test activities and communicate the results afterwards.

Conclusion:

A covert test must be properly authorized and controlled to evaluate detection capabilities without creating unnecessary risks.

Red Team Excercise vs. Vulnerability Assesment:

scenario: A bank wants to test its physical and digital security.

A. Red team Excercise:

1, Simulates realistic attackers to evaluate the bank's security.

2, Tests authorized physical access controls and digital denses.

3, Requires strict rules for attack simulations, emergency stops and protection of customer data.

B. Vulnerability Assesment:

1, Uses Approved scanning and testing methods.

2, Classifies vulnerabilities according to their severity.

3, Avoids recommendations to fix identified weaknesses.

Conclusion:

Red teaming evalutes the organization's response to realistic attacks, while Vulnerability assesment focuses on finding and priortizing security weaknesses.